



PROFESOR:

Alexis Moisés Montaño Araujo

MATERIA:

DBA

ALUMNO

José Mario Rivera Félix

GRUPO:

4 – 1

1. Introducción

Durante el laboratorio se analizaron los principales riesgos relacionados con la privacidad y la protección de datos personales dentro de una base de datos PostgreSQL. Se trabajó con información de clientes y se identificó la importancia de controlar quién puede acceder a ella, para qué puede utilizarse y durante cuánto tiempo debe conservarse.

El problema principal abordado fue la posibilidad de que los datos personales se recopilen, almacenen o consulten sin una justificación adecuada. También se estudiaron los riesgos de otorgar permisos excesivos, utilizar información real para pruebas de desarrollo y conservar datos durante periodos prolongados sin una política definida.

El objetivo fue proponer medidas técnicas y administrativas que permitan proteger la información, reducir los riesgos de exposición y garantizar que el tratamiento de los datos tenga una finalidad legítima y claramente definida.

2. Inventario de datos

Los datos identificados se clasifican según su nivel de identificación, sensibilidad y necesidad para las operaciones de la organización.

Dato	Clasificación	Protección recomendada
ID del cliente	Identificador interno	Restringir su acceso cuando permita relacionar registros personales.
Nombre completo	Dato personal identificativo	Limitar su consulta a los usuarios autorizados.
Correo electrónico	Dato personal identificativo	Restringir su acceso y protegerlo contra usos no autorizados.
Teléfono	Dato personal identificativo	Permitir su consulta únicamente cuando sea necesario.
RFC	Dato personal identificativo de especial relevancia fiscal	Restringir su acceso y justificar su recopilación y conservación.

Edad	Dato personal	Utilizar rangos de edad cuando el análisis no requiera la edad exacta.
Fecha de nacimiento	Dato personal	Limitar su recopilación y acceso a finalidades justificadas.
Ciudad	Dato de ubicación	Utilizarla de forma agregada cuando sea suficiente para los análisis.
Código postal	Dato de ubicación que puede contribuir a identificar personas	Evitar su exposición cuando no sea necesario.
Ingresos o salario	Dato personal económico	Aplicar controles reforzados y limitar su utilización a finalidades justificadas.
Ocupación y estado civil	Datos personales	Recopilarlos únicamente cuando exista una necesidad concreta.

3. Finalidades

Cada dato personal debe recopilarse y utilizarse para una finalidad específica, legítima y documentada. No es adecuado almacenar información simplemente porque podría ser útil en el futuro.

Las principales finalidades identificadas son:

Gestión de clientes: utilizar los datos indispensables para registrar a los clientes y administrar sus cuentas.

Contacto y comunicación: utilizar el correo electrónico o el teléfono cuando sean necesarios para atender solicitudes o proporcionar información relacionada con el servicio.

Facturación: utilizar los datos fiscales, como el RFC, cuando sean necesarios para cumplir con las obligaciones correspondientes.

Analítica: generar estadísticas y reportes mediante datos agregados o anonimizados, evitando exponer identificadores personales.

Marketing: utilizar datos de contacto para campañas únicamente cuando exista una base legal adecuada y se respeten las preferencias y los derechos de los clientes.

Auditoría y seguridad: conservar registros de accesos y operaciones para investigar incidentes y comprobar el cumplimiento de las políticas.

4. Minimización

El principio de minimización establece que deben recopilarse únicamente los datos personales adecuados, pertinentes y necesarios para cumplir con una finalidad determinada.

Durante el análisis se identificó que algunos campos podrían eliminarse o limitarse dependiendo de las necesidades reales del sistema.

-El salario, la ocupación y el estado civil deben excluirse si no existe una finalidad específica que justifique su recopilación.

-El RFC debe solicitarse únicamente cuando sea necesario, por ejemplo, para determinados procesos de facturación.

-La fecha de nacimiento completa puede sustituirse por una verificación de edad o un rango de edad cuando eso sea suficiente.

-El teléfono debe ser opcional cuando no sea indispensable para prestar el servicio.

-La dirección y el código postal deben solicitarse cuando sean necesarios para entregas, facturación u otra finalidad justificada.

-Para analítica, deben utilizarse estadísticas agregadas o datos adecuadamente anonimizados en lugar de copias completas de la información personal.

5. Control de acceso

El control de acceso debe relacionarse directamente con las funciones y responsabilidades de cada usuario. Para ello, se propone utilizar roles de PostgreSQL y conceder únicamente los permisos necesarios para cada actividad.

Los usuarios de soporte podrían consultar una vista con los datos indispensables para atender a los clientes, sin acceso directo a la tabla completa. El personal de analítica debería consultar vistas o conjuntos de datos agregados. Los desarrolladores deberían utilizar datos sintéticos para las pruebas y no recibir automáticamente copias de producción.

El DBA tendría permisos administrativos para gestionar la infraestructura, los roles, las copias de seguridad y los controles técnicos, pero sus actividades también deberían estar sujetas a auditoría.

Además, se deben revisar periódicamente los permisos, revocar los accesos que ya no sean necesarios y registrar las operaciones relevantes. De esta forma, se aplica el principio de mínimo privilegio y se reduce el riesgo de accesos indebidos.

6. Derechos ARCO

Los derechos ARCO son los derechos de acceso, rectificación, cancelación y oposición relacionados con el tratamiento de datos personales. Su atención requiere procedimientos administrativos y mecanismos técnicos dentro de la base de datos.

Acceso: permitir localizar los datos personales de un cliente y preparar una respuesta sobre la información que se encuentra bajo tratamiento.

Rectificación: permitir corregir información incorrecta o incompleta, manteniendo la integridad de los registros relacionados.

Cancelación: contar con procedimientos para eliminar los datos cuando corresponda, considerando las obligaciones legales de conservación y las excepciones aplicables.

Oposición: permitir registrar y aplicar restricciones al tratamiento cuando proceda, por ejemplo, para determinados usos promocionales.

Desde el punto de vista técnico, es necesario identificar al solicitante, verificar su identidad, localizar sus registros y determinar qué sistemas y copias contienen su información. También se deben documentar las acciones realizadas y comunicar al responsable de privacidad cualquier limitación técnica o legal.

La atención de una solicitud ARCO no consiste únicamente en ejecutar una consulta o un `DELETE`. Es necesario evaluar la solicitud, determinar si procede y ejecutar las acciones autorizadas conforme a los procedimientos y plazos aplicables.

7. Retención

La retención de datos consiste en establecer durante cuánto tiempo debe conservarse la información personal antes de eliminarla o aplicar otra medida autorizada.

El periodo de conservación debe determinarse de acuerdo con la finalidad del tratamiento, las obligaciones legales aplicables, las necesidades operativas y los riesgos relacionados con el almacenamiento de información.

Para implementar una política de retención, se propone:

-Documentar la finalidad de cada categoría de datos.
-Identificar las obligaciones legales que establecen periodos de conservación.
-Definir plazos para cada categoría de información.
-Revisar periódicamente los registros almacenados.
-Eliminar o anonimizar los datos cuando dejen de ser necesarios, siempre que proceda.
-Considerar las copias de respaldo y establecer procedimientos para su eliminación

conforme a los plazos definidos.
-Mantener evidencia de las eliminaciones y de las excepciones justificadas.

No debe establecerse un único periodo de conservación para todos los datos. Por ejemplo, los datos necesarios para cumplir obligaciones fiscales podrían tener que conservarse durante un plazo diferente al de los datos utilizados para estadísticas internas.

8. Gobierno de datos

El gobierno de datos establece las responsabilidades de las personas y áreas que intervienen en la recopilación, utilización, protección y conservación de la información.

Responsable	Funciones principales
DBA	Administrar la base de datos, configurar roles y permisos, aplicar controles técnicos, gestionar respaldos y mantener registros de auditoría.
Responsable de privacidad	Supervisar las políticas de privacidad, coordinar la atención de solicitudes y verificar el cumplimiento de los procedimientos de protección de datos.
Área jurídica	Interpretar las obligaciones legales, evaluar las bases jurídicas del tratamiento y asesorar sobre conservación, cancelación y otras obligaciones.
Propietario de los datos	Definir las necesidades del negocio, justificar las finalidades y determinar qué información necesita cada área.
Desarrollo	Implementar las aplicaciones y utilizar datos de prueba adecuados, evitando exponer información real innecesariamente.
Analítica	Generar reportes con datos agregados o anonimizados y respetar los permisos establecidos.

Marketing	Utilizar los datos de contacto conforme a las finalidades autorizadas, las bases legales aplicables y las preferencias de los clientes.
Auditoría	Revisar los controles, evaluar los registros de actividad e identificar incumplimientos o riesgos.

La responsabilidad debe estar distribuida. El DBA es responsable de implementar y mantener controles técnicos, pero no debe decidir por sí solo para qué se recopilan los datos ni determinar unilateralmente las obligaciones legales de la organización.

9. Evaluación integral

Durante el laboratorio se identificaron los siguientes riesgos principales:

-Acceso excesivo a los datos personales por parte de empleados que no necesitan consultarlos.
-Falta de separación entre los datos operativos y los utilizados para analítica.
-Recopilación de información personal sin una finalidad documentada.
-Exposición de identificadores como el nombre, correo electrónico, teléfono y RFC.
-Uso de copias completas de producción en entornos de desarrollo.
-Conservación de datos durante periodos prolongados sin una política definida.
-Posible utilización de datos de contacto para campañas sin verificar la base legal y las preferencias de los clientes.
-Falta de trazabilidad suficiente para investigar accesos o extracciones indebidas.
-Riesgo de reidentificación al combinar datos que aparentemente no identifican directamente a una persona.
-Ausencia de procedimientos claros para eliminar datos y atender solicitudes ARCO.
-Falta de definición de responsabilidades entre las áreas técnicas, jurídicas y operativas.
-Posible exposición de información en copias de seguridad y otros entornos que no cuentan con controles equivalentes a los de producción.

Para reducir estos riesgos, se propone aplicar controles de acceso basados en roles, minimizar los datos recopilados, utilizar vistas restringidas, generar estadísticas con información agregada, emplear datos sintéticos para desarrollo y establecer políticas documentadas de retención, eliminación y auditoría.

La evaluación debe repetirse periódicamente para comprobar que los controles continúan siendo adecuados y que los riesgos residuales se encuentran dentro de los niveles aceptados por la organización.

10. Conclusiones

El laboratorio permitió comprender que la protección de datos personales no depende únicamente de utilizar contraseñas o configurar correctamente un servidor PostgreSQL. También requiere definir finalidades, limitar los permisos, justificar la recopilación de información y establecer periodos de conservación adecuados.

Se identificó que una base de datos puede estar técnicamente protegida y, aun así, presentar problemas de privacidad si almacena información innecesaria o permite utilizarla para finalidades no justificadas.

Asimismo, se comprendió que el DBA desempeña un papel fundamental en la implementación de controles técnicos, pero debe trabajar en conjunto con los responsables de privacidad, el área jurídica y los propietarios de los datos.

En conclusión, la privacidad debe considerarse desde el diseño de la base de datos y durante todo el ciclo de vida de la información. La aplicación de los principios de minimización, mínimo privilegio, limitación de la finalidad, retención y responsabilidad proactiva permite reducir los riesgos y mejorar la administración de los datos personales.

27. Preguntas de reflexión

1. ¿Una base de datos técnicamente segura necesariamente cumple con todos los requisitos de privacidad?

No. Una base de datos puede contar con cifrado, contraseñas seguras y controles de acceso, pero aun así incumplir los principios de privacidad si recopila datos innecesarios, los utiliza para finalidades no justificadas o los conserva durante demasiado tiempo. La seguridad protege la información, mientras que la privacidad también determina cómo y para qué debe utilizarse.

2. ¿Por qué el principio de mínimo privilegio también contribuye a la privacidad?

Porque limita el acceso de cada usuario a la información estrictamente necesaria para realizar sus funciones. Esto reduce la exposición de datos personales, dificulta los usos indebidos y disminuye el impacto de una cuenta comprometida o de un error humano.

3. ¿Por qué el DBA no debería decidir por sí solo la finalidad del tratamiento de los datos?

Porque la finalidad depende de las necesidades del negocio, las decisiones de la organización y las obligaciones legales aplicables. El DBA debe implementar los controles técnicos necesarios para proteger la información, mientras que los responsables correspondientes deben definir y justificar las finalidades del tratamiento.

4. ¿Por qué los desarrolladores no deberían recibir automáticamente copias completas de bases de datos productivas?

Porque normalmente no necesitan todos los datos personales para desarrollar y probar una aplicación. Entregar copias completas aumenta el número de personas y sistemas que pueden acceder a la información, incrementando el riesgo de filtraciones. Es preferible utilizar datos sintéticos o conjuntos de datos reducidos y protegidos.

5. ¿Por qué una copia utilizada para desarrollo también puede representar un riesgo de privacidad?

Porque puede contener los mismos datos personales que la base de producción, pero encontrarse en un entorno con menos controles de seguridad. Si la copia se comparte, almacena o expone accidentalmente, puede revelar información de clientes. Por eso, los entornos de desarrollo también deben contar con controles adecuados y evitar el uso de datos reales cuando no sean necesarios.

6. ¿Por qué la retención debe formar parte del ciclo de vida de los datos?

Porque los datos no deben conservarse indefinidamente. Desde su recopilación se debe determinar cuánto tiempo serán necesarios, cuándo deberán revisarse y bajo qué condiciones podrán eliminarse. Una política de retención reduce la acumulación de información innecesaria y limita la exposición ante incidentes de seguridad.

7. ¿Qué relación existe entre privacidad por diseño y diseño de bases de datos?

La privacidad por diseño consiste en incorporar medidas de protección desde las primeras etapas del desarrollo. En una base de datos se refleja al definir únicamente los campos necesarios, separar la información según su finalidad, diseñar roles con permisos limitados y establecer mecanismos de retención, auditoría y eliminación desde el inicio.

8. ¿Qué controles técnicos implementarías para reducir el riesgo de exposición de datos personales?

Implementaría roles y permisos basados en el mínimo privilegio, vistas para limitar los datos visibles, cifrado de información, conexiones seguras, registros de auditoría y controles sobre las exportaciones. También utilizaría datos sintéticos para desarrollo, respaldos protegidos, revisiones periódicas de permisos y procedimientos para eliminar información cuando corresponda.

9. ¿Qué información debería conocer un DBA para responder técnicamente a una solicitud ARCO?

Debería conocer dónde se almacenan los datos personales, cómo se relacionan las tablas mediante identificadores, qué sistemas y copias contienen la información y qué usuarios tienen acceso. También necesitaría conocer los procedimientos autorizados para consultar, corregir, restringir o eliminar registros, así como las políticas de retención y las limitaciones técnicas o legales aplicables.

10. ¿Qué responsabilidades deberían corresponder al DBA, al responsable de privacidad, al área jurídica y al propietario de los datos?

DBA: implementar permisos, proteger la base de datos, gestionar respaldos, mantener la trazabilidad y ejecutar cambios autorizados.

Responsable de privacidad: coordinar las políticas de protección de datos, supervisar su cumplimiento y gestionar el proceso de atención de solicitudes.

Área jurídica: interpretar las obligaciones legales, evaluar las bases jurídicas del tratamiento y determinar las restricciones legales de conservación o eliminación.

Propietario de los datos: definir las finalidades, justificar qué información necesita la organización y establecer los requisitos de acceso y utilización para cada área.